

RBAC Permissions Matrix

Roles

Role	Code	Scope	Description
Admin	admin	System	IT/Technical owner. Manages system config, passwords, lookup tables.
Director of Services	director	All Locations	Oversees all houses. Hiring, client admissions, policy.
Program/Site Director	site_director	Assigned Location(s)	Manages one house. Scheduling, documentation, team supervision.
DSP (Caregiver)	dsp	Active Shift	Direct care. Access limited to currently assigned clients.

Permissions Legend

- **C** = Create | **R** = Read | **U** = Update | **D** = Delete
- **—** = No Access
- **Scoped** = Access limited to their assigned location(s) and for DSPs, their active shift

General Rules

Inactive Clients (HIPAA): To maintain record integrity, all modifications (Create/Update/Delete) to data associated with an **Inactive Client** are disabled. This applies to Contacts, Enrollments, Residence History, and Behavior Tracking. To modify this data, the client must first be reactivated (Directors/Admins only).

System & Lookup Tables

Table	Admin	Director	Site Director	DSP
staff_roles	CRU + Deactivate	R	R	R
location_type	C + Deactivate	R	R	R
relationship_types	R (System)	R	R	R
client_residence_types	R (System)	R	R	R
permission_types	— (System)	—	—	—
task_status_types	R (System)	R	R	R
shift_end_status_types	— (System)	—	—	—

Table	Admin	Director	Site Director	DSP
<code>behavior_types</code>	CRU + Deactivate	CRU + Deactivate	R	R
<code>log_categories</code>	CRU + Deactivate	CRU + Deactivate	R	R
<code>document_categories</code>	CRU + Deactivate	CRU + Deactivate	R	R
<code>document_subcategories</code>	CRU + Deactivate	CRU + Deactivate	R	R

Note: "R (System)" indicates lookup tables that are managed via database seed/migrations and are read-only in the API. `permission_types`, `shift_end_status_types` are internal system configurations not exposed via API.

HIPAA Note: All lookup/reference tables use soft-delete (deactivate) instead of hard delete. This preserves historical context for records that reference these values. For `location_type`, creating a type with a previously used name creates a **new record** (new ID) to maintain strict historical separation.

Staff & Security

Table	Admin	Director	Site Director	DSP
<code>staff</code>	CRUD	R (Hierarchy)	R (Hierarchy)	R (Scoped)
<code>addresses</code>	CRUD	CRUD	R (Scoped)	R (Scoped)
<code>staff_permissions</code>	— (System)	—	—	—
<code>user_sessions</code>	— (System)	—	—	—
<code>audit_logs</code>	— (System)	—	—	—
<code>security_events</code>	— (System)	—	—	—
<code>encryption_keys</code>	— (System)	—	—	—

Staff Access Scoping:

- **Admin:** All staff members
- **Director:** Directors, Site Directors, and DSPs (excludes Admins)
- **Site Director:** All Site Directors and DSPs (for shift coverage assignments)
- **DSP:** Coworkers at same locations (via shift history) + Site Directors managing those locations

Note: Users can always view their own profile. Role hierarchy prevents viewing staff above your level.

Delete/Deactivation Rules:

- **Staff:** Uses **Soft-Delete** (Deactivate). Staff are set to `is_active=False` to preserve audit trails and shift history.
- **Addresses:** Uses **Hard-Delete**, but is restricted by database Referential Integrity. You can only delete an "orphaned" address (one not linked to any Client, Staff, or Location). Addresses linked to any historical record cannot be deleted.

Note: `staff_permissions`, `user_sessions`, `audit_logs`, `security_events`, and `encryption_keys` are internal system tables managed by backend services (Authentication & Audit). They do not have direct API endpoints exposed to the frontend.

HIPAA Note: `addresses` contain client residence information (PHI). Site Directors only see addresses for their program location and clients enrolled there. DSPs only see addresses for their work locations and clients assigned to shifts happening right now.

Locations & Clients

Table	Admin	Director	Site Director	DSP
<code>program_locations</code>	CRUD	R	R (Self)	R (Self)
<code>clients</code>	CRU + Deactivate	R	R (Scoped)	R (Scoped)
<code>client_contacts</code>	CRU + Deactivate	CRU + Deactivate	CRU + Deactivate (Scoped)	R (Scoped)
<code>client_residence_history</code>	CR + Deactivate	CR + Deactivate	R (Scoped)	R (Scoped)
<code>client_program_enrollments</code>	CR + Deactivate	CR + Deactivate	R (Scoped)	R (Scoped)

HIPAA Note: `client_residence_history` is **immutable** after creation (no Update allowed). Records are never deleted; the "End Residence" action sets an `end_date`. Creating a new residence automatically ends the previous one. Each record tracks `created_by`, `created_at`, `ended_by`, and `ended_at` for full audit trail.

HIPAA Note: `client_program_enrollments` follows the same immutability pattern. Enrollments cannot be edited; to correct errors, end the current enrollment and create a new one. Each record tracks `created_by`, `ended_by`, and `ended_at`.

Location Access Scoping:

- **Site Director:** Only their assigned program location
- **DSP:** Only locations where they have shift assignments

Shift Management

Table	Admin	Director	Site Director	DSP
<code>shift_templates</code>	CRU + Deactivate	CRU + Deactivate	CRU + Deactivate (Scoped)	R (Self)
<code>shift_positions</code>	CRU + Deactivate	CRU + Deactivate	CRU + Deactivate (Scoped)	R (Self)

Table	Admin	Director	Site Director	DSP
shift_position_tasks	CRU + Deactivate	CRU + Deactivate	CRU + Deactivate (Scoped)	R (Self)
shift_position_clients	CRU + Deactivate	CRU + Deactivate	CRU + Deactivate (Scoped)	R (Self)
shifts	CRU + Deactivate	CRU + Deactivate	CRU + Deactivate (Scoped)	R (Self)
shift_assignments	CRU + Deactivate	CRU + Deactivate	CRU + Deactivate (Scoped)	R (Self)

Shift Template Access Scoping:

- **Admin/Director:** All templates
- **Site Director:** Templates at their assigned program location
- **DSP:** Only templates for shifts happening right now - prevents seeing client assignments from other positions

Shift Position Access Scoping:

- **Admin/Director:** All positions - full CRU access
- **Site Director:** Positions at their assigned program location - full CRU access (scoped)
- **DSP:** Only their own position(s) from shifts happening right now - read-only, strict minimum necessary for client PHI

Note: DSPs cannot create or update shift positions. Only Admin, Director, and Site Director can manage positions.

Shift Position Tasks Access Scoping:

- **Admin/Director:** All position tasks
- **Site Director:** Position tasks at their assigned program location
- **DSP:** Tasks for their own position(s) from shifts happening right now - strict minimum necessary for client PHI

Shift Access Scoping:

- **Admin/Director:** All shifts
- **Site Director:** Shifts at their assigned program location
- **DSP (GET /shifts list):** Shifts at locations where they have any shift assignment - for schedule visibility across their work locations
- **DSP (GET /{shift_id} detail):** Only their own shifts (Self) - shifts they were actually assigned to (past, current, or future)

Shift Assignments Access Scoping:

- **Admin/Director:** All assignments - full CRU + Deactivate
- **Site Director:** Assignments for shifts at their assigned program location - full CRU + Deactivate (scoped)

- **DSP:** Only assignments for shifts they were assigned to - read-only to see coworkers on the same shift

Note: `shifts` and `shift_assignments` use soft-delete with `cancelled_at/cancelled_by` and `ended_at/ended_by` respectively for HIPAA audit trail. Both `shift_templates`, `shift_positions`, and `shift_position_tasks` use soft-delete with `is_active`, `archived_at`, and `archived_by` fields. Admin, Director, and Site Director (scoped to their location) can deactivate these resources. Deactivated items preserve historical context for care documentation.

Tasks & Logs

Table	Admin	Director	Site Director	DSP
<code>task_categories</code>	CRU + Deactivate	CRU + Deactivate	CR	R
<code>tasks</code>	CRU + Deactivate	CRU + Deactivate	CRU + Deactivate (Scoped)	CR (Scoped)
<code>shift_task_status</code>	RU	RU	RU (Scoped)	RU (Scoped)
<code>shift_task_status_history</code>	R	R	R (Scoped)	R (Self)
<code>shift_daily_logs</code>	CR	CR	CR (Scoped)	CR (Scoped)
<code>staff_log_read_status</code>	CR	R	R (Scoped)	CR (Self)

Task Categories:

- The frontend only exposes Read access for the `task_categories`.

Tasks:

- DSPs can create their own custom tasks.

Task Access Scoping:

- **Admin/Director:** All tasks (global + client-specific)
- **Site Director:** Global tasks + client-specific tasks for clients enrolled at their program location
- **DSP:** Global tasks + client-specific tasks for clients assigned via shifts happening right now

Shift Task Status:

- Task statuses are **auto-created** when: (1) shifts are created from templates, (2) staff are assigned to positions, or (3) custom tasks are added
- Updates only allow changing `status_id`, `notes`, and scheduling times (structural fields like `shift_id`, `task_id`, `shift_position_id` cannot be changed)
- DSPs can only update task statuses for shifts they are assigned to (not just same location)

- To "delete" a task status, set `status_id=4` with PUT method (preserves audit trail via `shift_task_status_history`)
 - **Side Effect:** If the task is a **Custom Task** (`is_custom=True`), setting status to 4 will also automatically Deactivate the underlying Task definition (`is_active=False`) to clean up the library. This allows DSPs to effectively "delete" the custom tasks they created.

Shift Daily Logs:

- Logs are **immutable** after creation (healthcare documentation standard)
- DSPs can read logs for any location where they have at least one shift assignment (past/present/future), allowing them to see care history for their workplace.
- DSPs can only **create** logs for shifts they are currently assigned to.

HIPAA Note: `tasks` can only be deactivated (not deleted) by Admin/Director. Tasks that have been executed are preserved for care history. Client-specific tasks (where `client_id` is not NULL) contain PHI and require scoped access.

HIPAA Note: `task_categories` can only be deactivated (not deleted) by Admin/Director. This preserves the ability to understand historical task classifications.

HIPAA Note: `shift_task_status_history` logs all status changes. When `changed_by` is NULL, the change was system-initiated (e.g., shift timeout auto-marking tasks as not_completed).

Behavior & Documents

Table	Admin	Director	Site Director	DSP
<code>behavior_types</code>	CRU + Deactivate	CRU + Deactivate	R	R
<code>client_behavior_configs</code>	CR + Deactivate	CR + Deactivate	R (Scoped)	R (Scoped)
<code>behavior_tracking_records</code>	CR	CR	CR (Scoped)	CR (Scoped)
<code>document_templates</code>	CRU + Archive	CRU + Archive	R	R
<code>client_documents</code>	CRUD	CRUD	CRUD (Scoped)	R (Scoped)
<code>client_document_audit_log</code>	R	R	R (Scoped)	R (Scoped)

HIPAA Note: `behavior_types` can only be deactivated (not deleted) by Admin/Director. This preserves historical tracking context.

HIPAA Note: `behavior_tracking_records` are immutable after creation (no Update/Delete) to maintain audit trail integrity.

HIPAA Note: `client_behavior_configs` can only be deactivated (not deleted) by Admin/Director. Creating a new config version automatically deactivates the previous one.

Document Audit Logs:

- `client_document_audit_log` records are system-generated whenever a document is Created or Updated.
- There is no direct endpoint to query this table; the data is exposed as metadata (e.g., "Last Reviewed By", "Revision Count") nested within the Client Document details.
- **Access is Read-Only (R)** for all roles because users cannot manually create or modify these logs; they can only view the resulting history.

Behavior & Document Access Scoping:

- **Admin/Director:** All clients (global access)
- **Site Director:** Restricted to clients enrolled at their **Assigned Location**.
- **DSP:** Restricted to clients assigned to them via **Active Shifts** (currently happening). This adheres to the HIPAA Minimum Necessary rule.

Communication

Table	Admin	Director	Site Director	DSP
<code>client_updates</code>	CR + Deactivate	CR	CR (Scoped)	CR (Scoped)
<code>client_update_reads</code>	CR	CR	CR (Scoped)	CR (Scoped)

Note: `client_updates` are immutable after creation (no Update). Only Admin can archive entries.

Client Update Reads:

- Represents "Read Receipts" for compliance tracking.
- **Create (C):** Users mark an update as read (creates a receipt).
- **Read (R):** There is no explicit endpoint to read this information. However, it is implicitly accessed and returned when reading `client_updates`.

Client Update Access Scoping:

- **Admin/Director:** All clients (global access)
- **Site Director:** Restricted to clients enrolled at their **Assigned Location**.
- **DSP:** Restricted to clients assigned to them via **Active Shifts** (currently happening).